Who Is Watching the Solar Farm's Network?

Research Report, Part A · Cognton AI Full-Time Hiring Exercise · Oct 22, 2026 · @mahaveer

Summary and answers to the five questions

A passive sensor in each control room can see almost every command that matters in a solar plant, because the protocols are clear text with no login, and it can do this at low cost without touching the plant. This report studies the plant (A1), the protocols (A2), real attacks and ten solar-park scenarios (A3), data (A4), rules (A5) and market (A6), and ends with the design of a working prototype (A.3).

Five conclusions that shape the prototype

1. The control-room switch is the right place to watch: one mirror port shows inverter, PLC, SCADA and grid-link traffic.
2. Valid-looking commands from the wrong sender are the main threat, so detection is about who may write what, from where and when, backed by machine learning for unusual behaviour.
3. No public dataset is a solar plant, so the prototype is trained and tested mainly on our own lab traffic, with public captures as independent checks.
4. India's CEA Cyber Security Regulations, 2026 (in force 1 April 2027) require an asset register, continuous monitoring, monitored remote access and 6-hour incident reporting. Those are things the product produces.
5. Large OT platforms are priced and built for single big sites. A park of many small plants needs a cheap, local, offline-tolerant box with one shared dashboard.

Pain point from the exercise	Short answer	Where
Many vendors, many protocols	Decode protocols in a passive sensor with open-source parsers, and convert every message into one common event record. No agent on any vendor device	A1.4, A2
Empty, remote rooms	Detect new devices from traffic (MAC, IP) and switch port tables; alert on a new device within seconds	A1.3, A3 (S1), A.3
Vendor remote access, firmware changes	One access gateway with MFA, time windows and recording; the sensor flags any vendor-side write with no approved session, and any firmware-version change	Below
Cost and skills gap	Open-source decoding, a mini-PC per room, rules first and ML second; plain-language alerts	A6
Slow links, no shared response	Detect and decide at the site; send only alerts and short summaries; one shared playbook and one	Below, A5

Pain point from the exercise	Short answer	Where
	central team	

Vendor remote access: how it works today and how to control it

Today (our assessment, to be confirmed with the company). Typical plants let an equipment vendor reach inverters and SCADA through a VPN tunnel, then RDP, SSH, a vendor tool or a vendor cloud portal, often with a shared account, an always-on tunnel and no recording. The real attacks in A3 reached their goals through the same kind of path: valid credentials plus remote access in Ukraine 2015, a misconfigured VPN appliance in KA-SAT, and valid accounts with built-in tools in Volt Typhoon.

Target model.

- One gateway in the DMZ is the only way in. No vendor traffic goes straight to Level 1 or 2.
- Named individual accounts, with a second factor.
- Access opens for an approved window tied to a maintenance ticket, then closes by itself.
- Every session is recorded.
- The sensor cross-checks: a Modbus write from the vendor address with no open gateway session, or outside the window, raises an alert.

Apache Guacamole is a free gateway that supports TOTP two-factor login (Guacamole manual), session recording including key events (release notes 1.0.0), and, in version 1.6.0, configurable time limits for logins and enforcement of access windows even for users already logged in (release notes via Fedora). This is the stretch goal B6. The CEA 2026 Regulations point the same way: remote access limited to troubleshooting and emergencies, risk-assessed for critical systems, continuously monitored and recorded (Beacon Security).

Spotting an unexpected firmware change. Three layers, from cheapest to hardest:

1. Poll the firmware-version register or device identification (Modbus function 43) and alert when it changes without an approved ticket.
2. Watch for firmware-update traffic: large transfers on the vendor's update path, or a device reboot followed by a changed identity.
3. Require signed firmware from vendors. The 2026 Regulations require vendors to provide digitally signed or validated patches and a bill of materials covering firmware (Beacon Security). The sensor cannot verify a signature itself, so this layer is a procurement control.

A passive sensor cannot see inside encrypted vendor channels. Those cases rely on layer 1 and on the gateway log.

Slow links and shared response

The rule is: **decide at the site, report centrally.** The raw traffic never leaves the control room.

Done at the site (on the sensor)	Sent to the central dashboard	Kept at site and pulled only on request
Packet capture, protocol decoding, device inventory, rule checks, ML scoring, alert writing	Alerts (about 1 KB each), inventory changes, a short summary every 5 minutes, a heartbeat	A rolling packet buffer (several days) for evidence

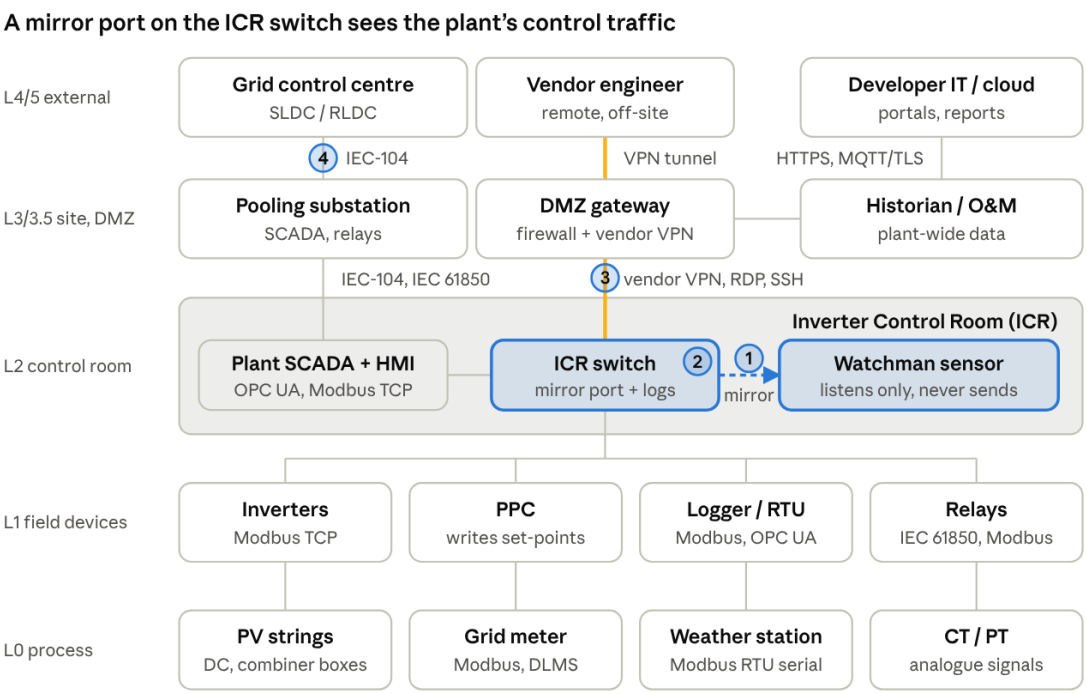
Design estimate: about 40 to 60 KB per hour in quiet periods. This is our own arithmetic, and stretch goal B7 measures the real figure. If the link drops, the sensor keeps detecting and queues alerts to send on reconnection; this directly answers the KA-SAT lesson in A3.

For the shared response, one central team watches all plants and follows one playbook (the rogue-device playbook in A5.3 is the first). Whether a park-level team can satisfy each developer's own obligations under the 2026 Regulations is one of our open questions.

A1. The plant: reference architecture

A utility-scale solar plant is a chain of small embedded devices (string monitors, inverters, meters, weather sensors) that report upward, through one control-room switch, into a SCADA system that also talks to the grid operator. Almost every link in that chain uses a protocol that was designed for reliability, not security. This chapter draws that chain, labels each link with its Purdue level and protocol, and marks the four places where a passive sensor can see traffic.

The reference plant below is a generic 100 MW-class solar plant of the type built in the Kutch desert parks. Where exact details differ between developers and vendors, the table says "typical" and the assumption is listed in Section A1.4.



Numbered circles mark where a sensor can listen: 1 ICR switch mirror port (main position)
2 switch MAC and port tables · 3 DMZ link to the vendor gateway · 4 uplink to the grid control centre
Heavy highlighted line: vendor access path (largest exposure). Dashed arrow: listen-only copy.

solar plant reference architecture · Purdue levels L0 to L5

Circles 1 to 4 are the places a sensor can listen. Circle 1, the ICR switch, is the main position and the only one the Part B prototype needs.

A1.1 The Purdue levels, in plain words

The Purdue model splits an industrial network into layers so that each layer only talks to its neighbours. Lower number means closer to the physical machine.

Level	Name	What lives here in a solar plant
0	Physical process	PV strings, string combiner boxes with current sensors, tracker motors, weather sensors (irradiance, module temperature, wind), meter CTs/PTs
1	Basic control	Inverter controllers, tracker controllers, protection relays, RTUs/PLCs, data loggers, the Power Plant Controller (PPC)
2	Area supervisory control	Inside the ICR: plant SCADA server, HMI, local historian, engineering workstation, ICR switches
3	Site operations	Plant-wide historian, O&M centre systems, pooling-substation SCADA, reporting and forecasting servers

Level	Name	What lives here in a solar plant
3.5	DMZ (IT/OT boundary)	Firewalls, remote-access gateway for vendors, data forwarders to the cloud, patch and antivirus servers
4/5	Enterprise / external	Developer's IT network, cloud portals, grid control centre (SLDC/RLDC), vendor clouds

The important point for our product: the sensor we are designing lives at **Level 2**, in the ICR, where traffic from Level 1 devices is already collected on one switch. One mirror port there shows almost everything that matters, without touching the plant.

A1.2 Link-by-link table (the reference architecture in words)

The diagram further below shows the same chain visually. Each row here is one link, from the panels up to the grid control centre, and ends with the vendor's remote-access path.

#	Link	Purdue level	Protocol and medium (typical)	Authentication / security note
1	PV strings → string combiner box / DC side of inverter	0	Analogue DC wiring; string monitors report over RS-485	No network security at this layer; physical access only
2	Weather station and trackers → data logger	0-1	Modbus RTU over RS-485 (serial)	None. Any device on the serial bus can read or write
3	Energy meter (CT/PT) → data logger / RTU	0-1	Modbus RTU or DLMS/COSEM (IEC 62056)	DLMS has optional authentication; often left at default
4	Inverter → ICR switch	1 → 2	Modbus TCP (SunSpec-style register maps) over copper or fibre Ethernet	None in the protocol. Some vendors add a web login on the inverter, often with default credentials
5	Power Plant Controller (PPC) → inverters	1	Modbus TCP set-point writes (active power limit, reactive power, power factor)	None. Whoever can write the set-point register controls plant output
6	Protection relays → plant SCADA	1 → 2	IEC 61850 (MMS reporting, GOOSE for fast signals) or Modbus TCP / IEC 60870-5-103 on older relays	IEC 62351 security exists but is rarely enabled; GOOSE is multicast and unauthenticated in practice

#	Link	Purdue level	Protocol and medium (typical)	Authentication / security note
7	Data logger / RTU → plant SCADA	1 → 2	Modbus TCP, OPC UA, or IEC 60870-5-104	OPC UA can be authenticated and encrypted; in practice often set to "None" mode
8	HMI and engineering workstation → SCADA server	2	Vendor-specific, RDP, or OPC UA	Windows accounts; usually shared logins
9	Plant SCADA → local historian → O&M centre	2 → 3	OPC UA, ODBC/SQL, MQTT or vendor protocol	Depends on setup; often unencrypted inside the fibre ring
10	Plant SCADA / RTU → pooling substation SCADA	2 → 3	IEC 60870-5-104 or IEC 61850 over the fibre network	IEC 104 has no authentication in the base standard
11	Pooling substation → grid control centre (SLDC/RLDC)	3 → 4	IEC 60870-5-104 (older sites: IEC 60870-5-101 serial) over MPLS/VPN/leased line	Network-level VPN protects the path, but any host inside can send IEC-104 commands
12	ICR / plant SCADA → DMZ → developer IT / cloud	3.5 → 4	HTTPS, MQTT over TLS, VPN	TLS protects data in transit; the risk is the credentials and the endpoints
13	Vendor engineer → remote gateway → inverter / SCADA / PLC	3.5 → 1-2	VPN + RDP / SSH / HTTPS vendor tools, sometimes a vendor cloud portal	Shared accounts, always-on tunnels, no session recording; the largest single exposure (see A3)

A1.3 Where one sensor can see the plant

We chose four observation points, in priority order. Only the first is needed for the Part B prototype.

1. **ICR core switch mirror port (SPAN) or TAP.** Shows inverter ↔ SCADA, PPC ↔ inverter, RTU ↔ SCADA and the IEC-104 link to the pooling substation. This is the main sensor position.
2. **Switch management plane (SNMP/syslog).** Tells us which MAC address appeared on which port and when a port went up or down. This catches a rogue laptop even if it stays silent, and also helps with the physical tampering question.
3. **DMZ link to the vendor gateway.** Shows who logged in, when, and which protocol they used on the way into Levels 1-2.

4. **Pooling-substation uplink.** Shows traffic to the grid control centre; useful to detect an unexpected IEC-104 command or a flood.

The sensor never sends anything onto the control network. It only receives a copy of the traffic, so a failure of the sensor cannot interrupt SCADA polling.

A1.4 How one tool can understand many vendors

The first pain point in the exercise is "many vendors, many protocols". Our answer has three layers:

- **Protocol parsers, not vendor agents.** Zeek with the CISA ICSNPP parsers already decodes Modbus, DNP3, IEC 60870-5-104 and several others into structured logs. We add no software to any vendor device.
- **A normalised event model.** Whatever the protocol, each decoded packet becomes the same small record: time, source device, destination device, protocol, function (read / write / command), target address (register or information object) and value. Rules and ML models work on this one record, so adding a new vendor means adding a register-map file, not new detection code.
- **A device registry built from traffic.** Devices are identified by MAC, IP, protocols spoken and role (for example "polls inverters" means SCADA server). This registry is the inventory in Part B (B3).

A1.5 Assumptions (to confirm with the company)

- Inverters in the reference plant are string or central inverters with a Modbus TCP interface; some vendors expose only a proprietary protocol or a cloud link, which a passive sensor cannot decode.
- The ICR switch supports port mirroring. Unmanaged switches would need an inline network TAP.
- IEC 60870-5-104 is used towards the grid control centre. Some sites may use IEC 60870-5-101 over serial, which needs a different tap.
- Plant-level details (IP ranges, register maps) differ by developer; the architecture above is a pattern, not a measured network.

A2. Listening to the machines: protocols on the wire

Modbus TCP and IEC 60870-5-104 carry commands as plain bytes with no login, no signature and no encryption, so any device that can reach the port can read data or send a command. This chapter shows what those packets look like, which protocols have any authentication at all, and what an attacker could send over each. It ends with the exact Wireshark steps to reproduce the findings from public captures.

A2.1 Which protocols have authentication?

Protocol	Where it appears in a solar plant	Port	Authentication in the base protocol	Optional security extension (rarely enabled)	What an attacker on the network could send
Modbus TCP	Inverters, meters, data loggers, PLC	TCP 502	None	Modbus/TCP Security (TLS, port 802)	Read any register; write coils or registers (set-points, run/stop); read device identification for reconnaissance
Modbus RTU	Serial links to meters, weather stations	RS-485	None	None	Same as above, but needs physical access to the serial bus
IEC 60870-5-104	Link to pooling substation and grid control centre	TCP 2404	None	IEC 62351-3 (TLS) and 62351-5 (message authentication)	Send control commands (single, double, set-point), counter interrogation, clock sync, reset process
IEC 61850 (MMS)	Substation relays and IEDs	TCP 102	Optional association-level password	IEC 62351-4 (MMS security)	Read and change relay settings, operate breakers if the association is accepted
IEC 61850 (GOOSE)	Fast signals between relays	Ethernet multicast (layer 2)	None	IEC 62351-6 (message signing)	Inject a forged trip or block signal that relays act on in milliseconds
DNP3	Some RTUs and utility links	TCP/UDP 20000	None in base	Secure Authentication v5 (challenge-response)	Send control relay output commands, cold restart, unsolicited response disable
OPC UA	SCADA to historian and logger	TCP 4840	Built in: security modes None, Sign, SignAndEncrypt, with user tokens	Already part of the standard	If a server accepts mode "None", read and write any node

Protocol	Where it appears in a solar plant	Port	Authentication in the base protocol	Optional security extension (rarely enabled)	What an attacker on the network could send
MQTT	Data to cloud / forwarders	TCP 1883 / 8883	Optional username and password	TLS on 8883	Publish fake telemetry or subscribe to all topics if the broker is open

The pattern is consistent: the older the protocol, the less it protects itself, and the security extensions exist on paper but depend on vendor support and on someone turning them on. That is why a monitoring layer, rather than a patch, is the realistic first defence.

A2.2 Anatomy of the three messages the exercise asks for

The byte examples below are worked by hand from the protocol specifications, so you can recognise them in Wireshark. They are illustrative; real captures will have different addresses and values.

1. Modbus read. A Modbus TCP frame starts with a 7-byte header (transaction ID, protocol ID which is always 0, length, unit ID) followed by a function code and its data.

```
00 01 00 00 00 06 01 03 00 00 00 0A
```

This reads as: transaction 1, length 6, unit 1, function code 3 (read holding registers), start address 0, quantity 10. A SCADA server sends this every few seconds to read an inverter's power and voltage. A defender sees thousands per hour from the same source; that regularity is the baseline.

2. Modbus write. The only difference is the function code and what follows.

```
00 02 00 00 00 06 01 06 00 64 00 00
```

Function code 6 (write single register), register 100 (hex 0064), value 0. If register 100 were an inverter's active-power limit, this single packet would tell the inverter to stop producing power. Nothing in the protocol checks who sent it. The same applies to function codes 5, 15 and 16 (write coil, write multiple coils, write multiple registers).

3. IEC-104 command. An IEC-104 frame starts with the byte 0x68 and a length, then four control bytes and the data unit (ASDU). A single command has type ID 45 and cause of transmission 6 (activation).

```
68 0E 02 00 04 00 2D 01 06 00 01 00 E8 03 00 01
```

This reads as: start byte, length 14, control bytes, type 45 (single command), one object, cause 6 (activation), common address 1, object address 1000, command state ON. Type 46 is a double command (often used for breakers) and type 50 is a set-point command. Industroyer2 is built around sending frames of exactly this kind (ESET analysis); Netresec released three PCAP files of its IEC-104 traffic from sandbox execution (Netresec).

A2.3 What a defender can learn from just these fields

- **Who:** source and destination IP and MAC, and so which device plays which role.

- **What:** function code (read, write, diagnostics) or ASDU type (monitoring direction or control direction).
- **Where:** register number or information object address, which maps to a named signal (for example "inverter 2 active-power limit").
- **When and how often:** timing, which makes polling regular and an attacker's scan irregular.

This is the whole basis of the rules in Part B: *who may write which register, from where, at what time.*

A2.4 Wireshark steps to reproduce (author's task)

Public captures are scarce; the main sources are the 4SICS ICS lab captures from Netresec (about 350 MB, covering Modbus/TCP and IEC-104 among others), the indexed ICS-pcap collection, the Netresec list of public PCAP repositories and the IEEE DataPort Modbus ICS dataset, which includes Modbus flooding and man-in-the-middle captures. File names inside these collections differ, so use the filters below rather than relying on a name. Field names can vary slightly by Wireshark version; right-click a field and choose Apply as Filter to confirm.

Goal	Wireshark display filter	What to annotate in the screenshot
See all Modbus	`modbus`	Master and slave IPs, port 502, the regular request/response rhythm
Modbus read	`modbus.func_code == 3 || modbus.func_code == 4`	Function code, start register, quantity, the returned register values
Modbus write	`modbus.func_code == 5 || modbus.func_code == 6 || modbus.func_code == 15 || modbus.func_code == 16`	The writing host, the register written, the value, and the lack of any credential field
See all IEC-104	`iec60870_104`	APCI frame types (I, S, U), STARTDT handshake, master/outstation IPs
IEC-104 control command	`iec60870_asdu.typeid == 45 || iec60870_asdu.typeid == 46 || iec60870_asdu.typeid == 50`	Type ID, cause of transmission (6 = activation), object address, command value
Who talks to whom	Statistics → Conversations; Statistics → Endpoints	The list of devices; this is the seed of the inventory in B3

For command-line work, `tshark` gives the same data as a table, for example:

```
tshark -r capture.pcap -Y "modbus.func_code == 6" -T fields -e frame.time -e ip.src -e ip.dst -e modbus.reference_num
```

Use `tshark -G fields | grep modbus` to confirm field names on your version.

Figures to insert (from your own Wireshark session):

Figure	Content	Suggested caption
A2-1	A Modbus read request and response pair, expanded packet details	"Modbus read: no credentials anywhere in the frame"
A2-2	A Modbus write (function code 6 or 16) with the register and value highlighted	"Modbus write: any host on the network can send this"
A2-3	An IEC-104 control-direction ASDU (type 45/46/50, cause 6)	"IEC-104 command: valid frame, no sender verification"
A2-4	Statistics → Conversations for the same capture	"Devices visible from one mirror port: the starting point for the inventory"

A2.5 Findings

- Modbus TCP and IEC-104 as normally deployed accept commands from any reachable host.
- Security extensions exist (Modbus/TCP Security, IEC 62351, DNP3 SAv5, OPC UA security modes) but depend on vendor support and on being switched on, so a monitoring sensor cannot assume them.
- The same property that makes these protocols easy to attack makes them easy to watch: the fields that matter (sender, function, register, value) are in clear text, so a passive sensor can enforce "who may write what" without touching the devices.
- The sensor cannot read encrypted traffic (OPC UA with encryption, TLS vendor channels, VPN tunnels). For those we monitor metadata and the endpoints.

A3. Real attacks and attack scenarios

Every major attack on power systems so far used one of four routes: stolen or shared credentials, a trusted remote-access path, native industrial protocol commands, or damage to the communication link. A solar park has all four exposed. This chapter studies seven real cases, extracts what they have in common, and turns that into ten scenarios for a solar park.

Technique IDs below are from MITRE ATT&CK for ICS. Where a mapping is our own judgment, because public reports do not say which technique was used, it is marked "(inferred)". Note that MITRE has reorganised some firmware and credential techniques in recent versions (firmware now appears as T1693, default credentials as T1694.001); both numbers are given where it matters.

A3.1 Case-study table

Case	What happened	How the attacker got in	ATT&CK for ICS techniques	Lesson for a solar park
Ukraine, 23 Dec 2015 (BlackEnergy, KillDisk)	Remote intrusions at three regional distribution companies cut power to about	The companies believe the attackers had acquired	Valid Accounts (T0859), Remote Services	Valid credentials plus remote access were enough. Firmware

Case	What happened	How the attacker got in	ATT&CK for ICS techniques	Lesson for a solar park
	225,000 customers for 1 to 6 hours. Operators restored service by closing breakers by hand. (CISA IR-ALERT-H-16-056-01)	legitimate credentials beforehand and used remote access to reach the control systems	(T0886), Unauthorized Command Message (T0855, breaker opening), System Firmware (T0857, serial-to-Ethernet converters rendered inoperable by corrupted firmware), Data Destruction (T0809, KillDisk)	attacks on small gateways delayed recovery. A solar park's serial-to-Ethernet gateways and data loggers are the same class of device
Ukraine, Dec 2016 (Industroyer / CrashOverride)	Malware attacked a transmission substation. ESET describes Industroyer as containing implementations of four industrial protocols (IEC 60870-5-101, IEC 60870-5-104, IEC 61850 and OPC DA) (ESET)	Prior IT compromise, then pivot to the substation network (from public reporting)	Unauthorized Command Message (T0855), Denial of Service on protection relays (T0814, inferred), Data Destruction (T0809)	The malware spoke the grid operator's own protocols. IEC-104 commands from an unexpected host are exactly what our sensor must flag
Ukraine, April 2022 (Industroyer2, CaddyWiper)	A new variant targeting high-voltage substations. It implements only IEC-104, was compiled on 23 March 2022 and was scheduled to run on 8 April, with CaddyWiper scheduled ten minutes later to erase traces. The attack was foiled	Two-wave intrusion: first compromise no later than February 2022, a second in April to upload the malware (The Hacker News)	Unauthorized Command Message (T0855), Data Destruction (T0809)	Attackers wait inside for weeks. The IEC-104 traffic is detectable in a PCAP; Netresec published sandbox captures of it (Netresec), which we can use for testing

Case	What happened	How the attacker got in	ATT&CK for ICS techniques	Lesson for a solar park
	(ESET)			
TRITON / TRISIS, Aug 2017	Malware targeted Schneider Triconex safety controllers at a Saudi petrochemical plant by modifying firmware in memory (CISA MAR-17-352-01). A coding error caused a safety shutdown instead of silent control	Moved from the IT network into OT and installed malware on an engineering workstation; the US government attributes it to a Russian research institute (FBI/CISA advisory)	System Firmware (T0857 / T1693.001), Masquerading (T0849), Loss of Protection (T0837), Loss of Safety (T0880)	Attackers will target the protection layer. In a solar plant that means protection relays and the plant controller. A custom proprietary protocol (TriStation, UDP 1502) was used, so the sensor needs a way to flag unknown protocols on known devices
KA-SAT / Viasat, 24 Feb 2022 (AcidRain)	A wiper pushed through the satellite operator's management network disabled tens of thousands of modems. About 5,800 Enercon wind turbines in Germany lost remote monitoring and control, though they kept generating (Viasat hack, summary; The Stack)	A misconfigured VPN appliance gave the attacker access to the satellite network's trusted management segment (TechForge)	Loss of View (T0829), Denial of Control (T0813), Loss of Availability (T0826). The compromise itself was outside the OT network	A remote plant must stay safe when the link to the control centre is gone. Our design has to keep detecting and buffering locally (see slow-link mode, B7)
RedEcho, 2020 to 2021 (ShadowPad)	Recorded Future reported that a China-linked group targeted ten Indian power-sector organisations, including four of the five Regional Load	ShadowPad command-and-control infrastructure; IT-side access	None confirmed at the OT layer (public reports describe only IT-side access). Related ICS stages: Lateral	This is the one case about India. The Mumbai outage of October 2020 was speculated to be linked in media

Case	What happened	How the attacker got in	ATT&CK for ICS techniques	Lesson for a solar park
	Despatch Centres (report summary via EastMojo). The researchers assessed it as possible pre-positioning of access rather than an immediate attack (Malwarebytes)		Movement and Initial Access (inferred)	reports, but the Recorded Future report itself does not prove that. We treat it as a warning of intent, not of a proven grid attack
Volt Typhoon, 2023 to 2024	CISA, NSA and FBI assess with high confidence that the group is pre-positioning on IT networks to enable disruption of OT functions across several critical infrastructure sectors, including energy (CISA AA24-038A)	Internet-facing appliances, then living-off-the-land: built-in admin tools and valid accounts, with minimal malware (CISA AA24-038A)	Valid Accounts (T0859, inferred), Remote Services (T0886, inferred)	No malware means no antivirus alert. Only behaviour (who connects to what, at which hour) shows the intrusion. This is the strongest argument for baseline-based detection

A3.2 What the cases have in common

1. **Credentials and remote access come first.** Ukraine 2015, TRITON and Volt Typhoon all start with a valid login or a trusted remote path. A solar park's vendor maintenance access is the same kind of path.
2. **The attacker speaks the plant's own protocols.** Industroyer and Industroyer2 send ordinary IEC-104 commands. The packets are valid; only the sender, time or target is wrong. Detection has to look at who commands what, not at malformed packets.
3. **Small devices are attacked to slow recovery.** Serial gateways, modems and loggers had their firmware wiped in Ukraine 2015 and KA-SAT. These are often outside the patch process.
4. **Losing the link is also an attack.** The KA-SAT outage did not touch the turbines; it took away the operator's eyes and hands.

A3.3 Ten attack scenarios for a solar park

Each scenario lists what a passive sensor at the ICR switch would see. A mark in the last column shows whether we plan to run it in Part B (final choice is in chapter A.3).

ID	Scenario	What the attacker does	ATT&CK for ICS	What the sensor sees	In Part B
S1	**Rogue laptop in the ICR**	Plugs into a free switch port in the unmanned room, gets an IP, starts looking around	Network Connection Enumeration (T0840), Remote System Discovery (T0846)	New MAC and IP never seen before, ARP requests, connections to many hosts	Yes
S2	**Changed inverter set-point**	Writes a new active-power limit (for example 0%) or a wrong reactive-power setting to an inverter's set-point register	Modify Parameter (T0836), Unauthorized Command Message (T0855)	Modbus write (function code 6 or 16) to the set-point register from a host that is not the plant controller	Yes
S3	**Abused vendor login at 2 a.m.**	Uses a valid vendor account outside the maintenance window and issues writes or reads	Valid Accounts (T0859), External Remote Services (T0822)	Session from the vendor gateway address at an unusual hour, unusual function codes or registers	Yes
S4	**Unexpected firmware change**	Pushes a firmware image to an inverter or gateway, or triggers firmware update mode	Activate Firmware Update Mode (T0800), System Firmware (T0857 / T1693.001)	Large transfer on the firmware-update path (HTTP/FTP/vendor port); a change in the reported firmware-version register	Optional
S5	**IEC-104 flood**	Opens many connections or sends command bursts to the substation / control centre link	Denial of Service (T0814)	Spike in packets per second and number of TCP sessions on port 2404, STARTDT retries	Yes
S6	**Unauthorized IEC-104 control command**	Sends a single or double command (type IDs 45 or 46) to open a breaker	Unauthorized Command Message	Control-direction ASDU from a host that is not the	Yes

ID	Scenario	What the attacker does	ATT&CK for ICS	What the sensor sees	In Part B
		or change a set-point (type ID 50)	(T0855)	registered master	
S7	**Spoofed or frozen telemetry**	Replays old readings so the operator sees normal values while the plant is manipulated	Spoof Reporting Message (T0856), Manipulation of View (T0832)	Values repeating exactly, impossible jumps, or readings inconsistent with each other (power vs irradiance)	Yes (ML)
S8	**Protocol reconnaissance**	Scans Modbus unit IDs and register ranges, or reads device identification (function 43)	Point and Tag Identification (T0861), Remote System Discovery (T0846)	Sequential reads across many registers or unit IDs; one host reading far more than the baseline	Yes
S9	**Controller stop or restart**	Stops the PLC program, or sends a Modbus diagnostics command (function 8) to restart communications	Change Operating Mode (T0858), Device Restart/Shutdown (T0816)	Rare function codes, write to run/stop coils, polling gap after the command	Optional
S10	**Uplink loss / telemetry freeze**	Takes down the WAN link or modem so the control centre goes blind (KA-SAT pattern)	Loss of View (T0829), Denial of View (T0815)	Polling stops, heartbeats missing; local traffic stays normal, so the sensor at the site can tell "link down" from "plant down"	Stretch (B7)

Two scenarios in this list cannot be detected by any passive sensor alone and are worth stating honestly: **S4** when the firmware is delivered over an encrypted vendor channel, and **S7** when the attacker replays traffic perfectly. For those we rely on the registers we can read (firmware-version register, value consistency) and we flag the limits in the report's hurdles section.

A4. Hunting for data

No public dataset is a solar plant, so the prototype should run mainly on traffic we generate ourselves and use public datasets only to check that our rules and models hold up on traffic we did not create. This

chapter compares the main public datasets, lists what a real control room would give us, and recommends a mix.

A4.1 Public datasets compared

The table separates **network datasets** (packet captures a passive sensor can read, which is our case) from **process datasets** (sensor and actuator values from a physical testbed, which help with the ML side but are not packets).

Dataset	Year	Type	Protocol / domain	Labelled attacks	Access and licence	Fit for this project
CIC Modbus 2023	2023	Network (pcap + attack logs)	Modbus TCP, simulated substation	9: reconnaissance, query flooding, loading payloads, delay response, modify length parameters, false data injection, stacking Modbus frames, brute-force write, baseline replay	Free; redistribution allowed with citation of the dataset and paper	**High.** Closest match for inverter polling and set-point writes
IEC 60870-5-104 Intrusion Detection Dataset (Radoglou-Grammatikis et al.)	2022	Network (pcap + labelled flow CSVs)	IEC-104; 7 industrial entities, 1 HMI, 3 attackers	12 attacks: unauthorised commands and DoS	Public on Zenodo; cite the authors' paper; check the record for licence terms	**High.** Matches the grid-operator link (S5, S6)
DNP3 Intrusion Detection Dataset	2022	Network (pcap + labelled flows)	DNP3; 8 industrial entities, 1 HMI, 3 attackers	9 DNP3 attacks (for example warm restart, enumerate, info)	Public on Zenodo; check the record for licence terms	Low-medium. We do not use DNP3, but the attack types (enumeration, restart) are useful ideas
Cyber-security	2019	Network	Modbus TCP, small	Modbus query flooding, man-	IEEE DataPort	Medium-high. Good for

Dataset	Year	Type	Protocol / domain	Labelled attacks	Access and licence	Fit for this project
Modbus ICS dataset		(pcap)	process testbed	in-the-middle with data change, others	(free account)	flooding and in-flight data modification (S5, S7)
Electra Modbus & S7comm (see the 2024 dataset review)	2019	Network	Modbus and S7comm	7 attack types	Public; check source	Medium
Dataset for NIDS on SCADA IEC 60870-5-104	2022	Network (pcap)	IEC-104 distribution testbed	ICMP flood, SYN flood, IEC-104 flood with unknown type ID	**Restricted** (access request on Zenodo)	Medium; useful for S5 if access is granted
HAI (HIL-based Augmented ICS)	2020, 2021	Process (sensor values)	Steam-turbine and pumped-hydro emulation	38 attacks in the first release (HAI 20.07, about 123 hours of test data)	Public on GitHub and Kaggle	Medium for ML on physical values (S7 consistency checks); no packets
SWaT and WADI (iTrust, SUTD)	2015 to 2017	Process + some network	Water treatment and distribution	Labelled attacks (WADI: 16 days, 2 with attacks, 123 sensors and actuators)	Free **on request** (survey)	Low. Water domain; request delay
MSU / ORNL power system datasets (Morris et al.)	2014 onward	Process + logs	Synchrophasor, relay, Snort and control-panel logs	37 scenarios per set: 1 normal, 8 natural events, 28 attacks (remote trip command, relay setting change, data injection) (description)	Public download	Medium for the "false data / protection" idea; not Modbus/IEC-104 packets
4SICS ICS	2015,	Network	Modbus	**Unlabelled**	Public	Good for

Dataset	Year	Type	Protocol / domain	Labelled attacks	Access and licence	Fit for this project
lab captures and Industroyer 2 sandbox captures	2022	(pcap)	TCP, IEC-104, others		(Netresec)	Wireshark study (A2) and a realistic IEC-104 attack test; not for training

Limits shared by almost all of them. A recent review notes that host logs are entirely missing, most datasets inject only a narrow set of attacks, DoS is often absent, and class imbalance is severe because attacks are injected manually (review of CPS datasets). None is a solar plant, and several are simulated rather than recorded on real equipment.

A4.2 What a real control room would give us

This is the data we would collect in a real deployment, and what each source enables.

Source	What it contains	How we get it	What it enables	Volume / cost
Packet capture from the ICR switch (SPAN or TAP)	Every Modbus, IEC-104, OPC UA and HTTP exchange	Mirror port to the sensor	Protocol decoding, rules, device inventory, ML on timing and values	Highest: the data we reduce locally
Switch tables and port state (SNMP, syslog)	MAC address per port, link up/down, port security events	Poll the switch	Rogue device and tamper detection even if the device stays silent	Tiny
Inverter registers	Power, voltage, current, status and fault codes, firmware version, set-points	Already read by SCADA; the sensor sees it in traffic	Consistency checks, firmware-change detection, ML	Small, regular
SCADA alarms and event log	Operator actions, alarm states, setpoint changes	Export or syslog from the SCADA server	Matches a network command with a human action: "was this change approved?"	Small
Historian time series	Long-term power, irradiance, temperature	Historian query	Baselines for slow drift and spoofed-data checks	Medium
Remote-access	Login, source IP, time,	Gateway	Vendor-access monitoring	Small

Source	What it contains	How we get it	What it enables	Volume / cost
gateway logs	session start and end	export	(S3)	
Firewall and VPN logs at the DMZ	Allowed and denied flows	Syslog	Cross-check with sensor view; spot new paths	Small to medium
Weather station data	Irradiance, module temperature, wind	Already on the network	Check that reported power matches conditions	Small

For the prototype, only the first three rows are simulated. The others are listed so the design can grow without changing the data model.

A4.3 Recommendation

Use a hybrid: lab traffic as the main dataset, public datasets as independent checks.

1. **Lab traffic (main).** Generate days of normal traffic from the simulated inverters, PLC, HMI and IEC-104 link in Part B, then inject our own scenarios. This is the only way to get a clean "normal" baseline for our exact device set and to know every attack's start time, which Part B needs to show detection time (B.2).
2. **CIC Modbus 2023 and the IEC-104 Zenodo dataset (validation).** Replay their pcaps through the same Zeek and detection pipeline to check that our Modbus and IEC-104 rules also fire on traffic made by other people. This tests whether we have only fit our own lab.
3. **Industroyer2 sandbox captures (demonstration).** Use the Netresec IEC-104 files as a realistic example of a hostile IEC-104 conversation for the report and, if the licence and file format allow, the demo.
4. **HAI (optional, ML on values).** Only if time permits, to try the value-consistency ML model on a labelled process dataset.

We do not recommend SWaT or WADI for this prototype: they are water-sector, need an access request, and add delay without matching our protocols.

A5. The rules: CEA, IEC 62443 and CERT-In

Indian power-sector cybersecurity moved from advice to law this year: the CEA (Cyber Security in Power Sector) Regulations, 2026 were notified on 31 July 2026 and come into force on 1 April 2027, replacing the 2021 Guidelines. This changes the sales argument for our product, because several things the regulations require (an asset register, continuous monitoring, monitored remote access, a six-hour reporting clock) are exactly what a passive watchman produces.

Source note. The summaries below rely on law-firm, consultancy and trade-press summaries of the notified text, because the regulation is long and partly deferred. Where a requirement matters for the design, the Gazette text should be read directly: the notification is linked from the Beacon Security guide as an e-Gazette PDF. Nothing here is legal advice.

A5.1 What each framework requires

Framework	Status	Requirements that matter to a solar park	What the watchman gives
CEA (Cyber Security in Power Sector) Regulations, 2026	Notified 31 Jul 2026; in force 1 Apr 2027 (PwC India, Indian Infrastructure)	Applies to generating companies, captive plants and storage at 50 MW and above, plus transmission, distribution and load despatch, and to vendors. Requires a cyber asset register and a record of critical systems with data flows and protocols; continuous monitoring and an incident register; OT perimeter devices that can detect and filter OT protocols; remote access limited, risk-assessed, monitored and recorded; OT isolated from IT and the internet by default, with unidirectional gateways where connected; sensitive data stored encrypted within India; a CISO and alternate CISO and a 24-hour information security division; annual audits and self-audits (Beacon Security). Incidents go to CSIRT-Power and CERT-In within 6 hours; cyber sabotage in critical systems within 24 hours (Indian Infrastructure)	Live asset inventory, continuous passive monitoring, alert record with reasons, evidence for the 6-hour report
CEA Cyber Security Guidelines, 2021	Voluntary, framed under the 2019 grid-connectivity technical standards; replaced by the 2026 Regulations (Drishti IAS)	CISO and information security division at each responsible entity; sabotage report to the sectoral CERT and CERT-In within 24 hours; six-monthly audit by a CERT-In empanelled auditor; trusted-source procurement (Swarajya)	Same as above; useful as the history of how requirements tightened
CERT-In Directions, 28 Apr 2022 (under Section 70B(6), IT Act)	Binding; effective June 2022 (Nishith Desai)	Report listed incidents within 6 hours of noticing them; keep logs of all ICT systems securely in India for a rolling 180 days; synchronise clocks to NIC or NPL NTP servers. The listed incidents include targeted scanning or probing of critical systems (Khaitan & Co)	Time-stamped, tamper-evident alert log; recon alerts (S1, S8) map directly to a listed incident type
IEC 62443	Voluntary	Asset owners build a security programme (2-1),	Foundational

Framework	Status	Requirements that matter to a solar park	What the watchman gives
(ISA/IEC series)	international standard; widely used as the technical yardstick	divide the plant into zones and conduits with target security levels (3-2), and meet system requirements (3-3) across seven foundational requirements; product makers follow secure development (4-1) and component requirements (4-2) (IEC cybersecurity guidance, Cisco overview of 62443-3-3)	requirement 6, timely response to events (audit-log access, continuous monitoring); evidence of zone and conduit behaviour

Two points follow for the design. First, because the 2026 Regulations apply to **vendors**, a company selling this product into a plant becomes subject to the vendor chapter: documented restoration, signed patches for the product's life, end-of-support dates, a bill of materials for components including firmware, and a vulnerability-disclosure process (Beacon Security). Second, six provisions are deferred to later orders (including the round-the-clock security division and trusted-source procurement), so the final shape of some obligations is not yet known.

A5.2 Compliance checklist: what our product covers

A mark of **Yes** means the prototype demonstrates it; **Partly** means it supplies evidence but the plant owner must do the rest; **No** means it is outside what a passive sensor can do.

Requirement	Source	Prototype
Cyber asset register with data flows and protocols	CEA 2026	**Yes**: inventory built from traffic (B3)
Continuous monitoring of OT and an incident register	CEA 2026	**Yes**: sensor, alerts, timeline (B4, B5)
Detect OT-protocol misuse at the boundary	CEA 2026	**Partly**: we detect; filtering stays with the firewall
Remote access monitored and recorded	CEA 2026	**Partly**: vendor-session alerts (S3); full session recording is stretch B6
Logs kept in India for 180 days	CERT-In 2022; CEA 2026	**Partly**: configurable retention; deployment in an Indian region is a design rule
Clock sync to NIC / NPL time	CERT-In 2022	**Partly**: sensor timestamps must use a synchronised clock; design note

Requirement	Source	Prototype
Report an incident within 6 hours	CERT-In 2022; CEA 2026	**Partly**: each alert carries who, what, where, when and why, ready to paste into a report
Sabotage report within 24 hours	CEA 2021, 2026	**Partly**: playbook below
Unidirectional gateway between OT and IT	CEA 2026	**Design rule**: the sensor's uplink only sends out, and never accepts commands from the central dashboard
CISO, alternate CISO, 24-hour security function	CEA 2026	**No**: owner's duty; our dashboard supports a 24-hour view
Annual audit, penetration test before commissioning	CEA 2026	**No**: owner's duty; a passive sensor does not disturb the audit
Vendor duties (patches, bill of materials, disclosure)	CEA 2026	**Our own duty** as a vendor

A5.3 Playbook: rogue device found in the ICR

The two legal clocks (6 hours and 24 hours) come from the sources above. Everything else is our proposed procedure and should be adapted to each owner's Cyber Crisis Management Plan. T0 is the moment the sensor raises the alert. Principle: **availability and safety first**, so we contain the rogue device and never stop inverters or break control paths to do it.

When	Action	Who	Notes
T0	Sensor raises "unknown device" with MAC, IP, switch port, first-seen time and what it talked to. Severity High if it used an OT protocol or sent writes; Medium if it only appeared on the network	Sensor (automatic)	The alert states its reason in plain words
T0 to T0+5 min	Alert goes to the central dashboard and the on-duty analyst by SMS, email or call	Information security duty analyst	The ICR is unmanned, so nobody on site sees it
T0+5 to +15 min	Triage: check the maintenance and change list, vendor visit schedule and recent hardware replacements; check ICR door access and CCTV	Duty analyst with plant shift engineer	Most alerts end here as an approved contractor laptop
T0+15 to +30 min	If unapproved: shut down the switch port or block the MAC. **Do not** reboot or isolate inverters, PLCs or the SCADA server. Copy the packet ring buffer	Network engineer; approval	Containment only touches the

When	Action	Who	Notes
	and port table as evidence	from plant manager or CISO	rogue device
T0+30 to +60 min	Verify no harm: search the event log for any write or command from the rogue device; compare set-point registers with approved values	Duty analyst	Any write moves this to a full incident
Within 6 hours of detection	Report the incident to CSIRT-Power and CERT-In with the alert details and actions taken	CISO	Legal deadline
Within 24 hours, if sabotage is suspected in critical systems	File the sabotage report to CSIRT-Power and CERT-In (and to NCIIPC if the system is a protected system)	CISO	Legal deadline; the NCIIPC step comes from the 2021 Guidelines (Swarajya)
Within 7 days	Physical review of the ICR (locks, access log), credential rotation if the device authenticated anywhere, allow-list update, lessons learned; keep logs for at least 180 days	CISO, plant manager	Update the asset register and the Cyber Crisis Management Plan

A6. The market: what exists, what it costs, who would pay

The established OT-security platforms are built and priced for a single large site with its own security team, while the park has many small plants with none. The gap we can fill is a cheap, local, many-site watchman that also produces the evidence the new CEA regulations ask for. This chapter compares what is on the market and ends with a product pitch.

Source note. None of the large vendors publishes list prices. The figures below are the few public reference points found, mostly from marketplace listings reported by comparison sites, and they are signals, not quotes.

A6.1 Comparison

Product	Type	Deployment	Strengths	Pricing signal	Fit for a solar park
Nozomi Networks (Guardian, Vantage)	Commercial platform	Hardware, software or virtual passive sensors, on-	Broad device and protocol coverage; scales to many	A cloud bundle listed on AWS Marketplace at $218,880 per 12	Strong technically; priced for large estates

Product	Type	Deployment	Strengths	Pricing signal	Fit for a solar park
		premises console or cloud SaaS	sites (Decryption Digest)	months for up to 5,000 assets (RFP.wiki)	
Claroty (xDome, CTD)	Commercial platform	Sensors plus cloud or on-premises management; secure remote access module	Rich asset context; partnerships with Rockwell and Schneider; remote-access workflows (Decryption Digest)	Marketplace examples from about $100,000 a year (Essential) to about $1.2 million (Advanced), bundled with services (RFP.wiki)	Has the vendor-access feature we list as a stretch goal; heavy for small sites
Dragos	Commercial platform + services	Site sensors with central store; managed monitoring available	Deepest ICS threat intelligence (Decryption Digest)	A central subscription listed at $100,000 per 12 months for up to 50 connected site sensors (RFP.wiki); sensor licences and services are not shown in that listing	Best for threat intelligence; a cost model aimed at utilities
Tenable OT Security (Tenable One OT Exposure)	Commercial; exposure management	Passive monitoring plus optional active queries	Vulnerability and exposure prioritisation across IT and OT (Ciphers Security)	Quote only	Better for patch prioritisation than for attack detection; active queries are a risk on fragile devices
Microsoft Defender for IoT	Commercial, Azure-based	Passive sensors (appliance or VM) managed from the Azure portal;	Integrates with Microsoft Sentinel for one IT and OT view	Per-site licences by device count: from $70 a month for up to 100 devices and $150 a month for	Cheapest commercial signal; depends on Azure and a sensor

Product	Type	Deployment	Strengths	Pricing signal	Fit for a solar park
		air-gapped use is supported; the on-premises management console was retired on 1 Jan 2025 (Microsoft Learn)		up to 250 (Microsoft pricing page). A reseller reports the OT site licence left its price list in September 2026 and that other routes remain (O365HQ)	appliance; availability of the licence needs checking
Security Onion	Open-source distribution	Linux distribution for network security monitoring	Bundles capture, intrusion detection and search	Free software	General-purpose, not OT-first
Malcolm (with Zeek and CISA ICSNPP parsers)	Open source from Idaho National Laboratory and CISA	Sensor (Hedgehog Linux) forwards metadata to a Malcolm server	Accepts PCAPs or Zeek logs; permissive licence; ICS protocol parsers (INL); a recent release added IEC-104 support using the CERT.LV Zeek plugin (Malcolm release notes)	Free software; cost is engineering time and hardware	The base of our prototype

Two readings of this table matter. First, per-site cost: if the Dragos central subscription really covers 50 sites, the headline figure averages about $2,000 per site per year before sensor licences, and Microsoft's list prices work out to roughly $840 to $4,800 per site per year for plants of up to 1,000 devices (our arithmetic from the figures above). These are not out of reach for a 100 MW plant, but they are quotes for one buyer at a time, with extra costs for sensor hardware, mirror-port work and services. Second, almost all of these products assume a cloud link or an on-premises server per site, which does not suit remote desert plants on slow links with unreliable power.

A6.2 What open source, cheap hardware and ML can do instead

- **Open source.** Zeek with the ICSNPP parsers (Modbus and others) plus a Suricata ruleset gives protocol decoding with no licence fee. One gap we found: the CISA ICSNPP packages are a list of

parsers that does not obviously include IEC-104; Malcolm added IEC-104 only recently through a separate CERT.LV plugin, so the IEC-104 parser is a risk to verify early (see open questions).

- **Cheap edge hardware.** One fanless industrial mini-PC per control room with two or three Ethernet ports (one receiving the mirror, one for management), an SSD, and a DC power supply with battery ride-through. No agents on plant devices.
- **ML where rules are weak.** An Isolation Forest or small autoencoder trained on a plant's own normal polling behaviour can flag unusual timing, new register-access patterns and inconsistent values that no hand-written rule anticipates. It runs on the same mini-PC. Its weakness is false alarms, so every ML alert must carry a plain-language reason and a confidence level, and rules stay the primary detector.
- **Honest limit.** This stack does not match the threat-intelligence depth of Dragos or the device-fingerprint databases of Nozomi and Claroty. Our claim is "good enough, cheap, and everywhere" rather than "best at one site".

A6.3 Who pays, and how

Buyer	Why they pay	Likely model
Park owner (the state power company)	One security view over many developers; evidence of oversight; reduced risk to the shared pooling substations	Park-wide subscription, one contract, per-site pricing, central dashboard included
Individual developers	Each plant of 50 MW or more falls under the 2026 Regulations from 1 April 2027 and needs a register, monitoring and 6-hour reporting	Per-site annual subscription, optionally with managed monitoring
O&M contractors	Contract obligations to show security hygiene	Bundled into the O&M contract, or pass-through
Grid operator links (pooling substation / state load despatch)	The IEC-104 uplink is the point where a bad command does the most harm	Add-on sensor at the substation

A6.4 Product pitch (one paragraph)

The Solar Park Watchman is a small box, one per control room, that listens passively to the plant network, learns every device and what normal looks like, and raises plain-language alerts when something unusual happens: a new laptop, a set-point changed by the wrong host, a vendor login at 2 a.m., or a flood on the grid link. It works offline, sends only short alerts and summaries over slow links, and rolls up into one dashboard for the whole park, so one small security team can watch dozens of plants. It is built on open-source decoding and priced per site at a fraction of enterprise OT platforms, and it produces the asset register, monitoring record and incident evidence that the CEA's 2026 cybersecurity regulations require from April 2027. **Price hypothesis to test with buyers: a few thousand US dollars per site per year including the appliance and the central dashboard.** This number is our assumption, not a finding.

A.3 Bridge to Part B: prototype design

The prototype is a mini control room in Docker with a passive sensor beside it. It runs seven of the ten scenarios from A3 against simulated inverters, a PLC and an IEC-104 link, and reports each detection with a plain-words reason. Everything runs locally; nothing touches a real plant or the internet.

A.3.1 Scenarios the prototype will detect

Six scenarios are required for the demo and one more (S7) is attempted as the machine-learning case. This is more than the minimum of four, so that the 95% target still holds if one scenario is only partly caught.

ID	Scenario (from A3)	How we run it in the lab	Detection method	Expected alert reason (plain words)
S1	Rogue laptop in the ICR	Start an `attacker` container on the control network, get an address and ping/ARP-scan	Inventory (B3): device not in the known list	"New device 10.10.1.99 (MAC …) appeared on the control network and has not been approved"
S2	Changed inverter set-point	From the attacker, write 0 to an inverter's active-power-limit register	Rule: only the plant controller may write set-point registers	"inverter-2 set-point written by 10.10.1.99; only 10.10.1.30 is allowed to write it"
S3	Abused vendor login out of hours	A `vendor-gw` container, known to the sensor as a vendor, issues reads and writes outside its maintenance window	Rule: vendor source, time window, function code	"Vendor gateway sent writes at 02:10; its approved window is 10:00 to 16:00"
S5	IEC-104 flood	Script opens many IEC-104 sessions and sends bursts of frames to the outstation	Rule on rate + ML on traffic features	"IEC-104 outstation received 40× its normal packet rate in 60 seconds from 10.10.1.99"
S6	Unauthorized IEC-104 command	Attacker sends a single or double command (type ID 45 or 46) to the	Rule: control-direction ASDU only from the	"Control command to breaker point 1000 came from 10.10.1.99; only the grid control

ID	Scenario (from A3)	How we run it in the lab	Detection method	Expected alert reason (plain words)
		outstation	registered master	centre master 10.10.2.10 may send commands"
S8	Protocol reconnaissance	Attacker scans unit IDs and reads many registers sequentially	Rule on distinct registers read per minute + ML	"10.10.1.99 read 300 distinct registers across 5 devices in one minute; normal is 12"
S7 (ML case)	Frozen / spoofed telemetry	Make an inverter server return the same power value while the weather input changes	ML on value behaviour + consistency check	"inverter-1 reported identical power for 20 minutes while irradiance varied"

A.3.2 Data

Use	Data	Why
Training the normal baseline	Traffic from our own lab, at least 12 hours of continuous normal operation (SCADA polling, PPC set-point updates, IEC-104 telemetry)	Only our own lab gives a clean baseline for our exact devices and the exact start time of each attack
Measuring false alarms	A separate held-out normal period (at least 1 hour) never used for training, plus the full overnight run	Avoids testing on training data
Independent check of rules	CIC Modbus 2023 pcaps and the IEC-104 Zenodo dataset replayed offline through the same Zeek pipeline	Shows the rules work on traffic made by other people
Demonstration	Industroyer2 sandbox IEC-104 captures from Netresec, replayed offline	Realistic hostile IEC-104 example

A.3.3 Architecture

Figure A.3-1 (below) shows the lab. Everything is in one Docker Compose file.

Layer	Component	Role	Tooling
Simulated devices (B1)	3 inverters	Modbus TCP servers with registers for power, voltage, status, firmware version and the active-power set-point	`pymodbus`

Layer	Component	Role	Tooling
	Plant controller (PPC)	The only legitimate writer of set-points	Python script
	PLC	Aggregates weather data, exposes Modbus	OpenPLC
	IEC-104 outstation and fake grid control centre	Sends telemetry up, accepts commands down	`lib60870`
	HMI / SCADA	Polls all devices normally	FUXA or ScadaBR
	`attacker` and `vendor-gw`	Run the scenarios	Python, `scapy`, `pymodbus` client
Passive sensor (B2)	Capture on the Docker bridge	Receives a copy of all control-network traffic; sends nothing	Zeek with CISA ICSNPP parsers; CERT.LV `spicy-iec104` for IEC-104; Suricata for signatures
Watchman logic (B3, B4)	Event normaliser	Turns Zeek logs into one record: time, source, destination, protocol, function, address, value	Python
	Device inventory	IP, MAC, protocol, role, first seen, last seen, approved flag	SQLite
	Rule engine	"Who may do what, from where, at what time", stored as a YAML policy	Python
	ML detector	Per-device, per-minute features; trained on normal traffic	scikit-learn Isolation Forest (autoencoder if time permits)
	Alert builder	Writes the alert with severity, reason, evidence and the ATT&CK for ICS ID	Python
Dashboard (B5)	Inventory, alerts, timeline	Shows devices, alerts with reasons, attack time next to alert time	Streamlit
Stretch (B7)	Summariser	Sends only alerts and 5-minute summaries to a central container; measures KB per hour	HTTP/MQTT

An alert looks like this:

```
{
 "time": "2026-11-08T14:02:11Z",
 "severity": "high",
 "scenario": "unauthorized_setpoint_write",
 "device": "inverter-2",
 "source": "10.10.1.99",
 "reason": "Register 101 (active power limit) was written by 10.10.1.99. Only 10.10.1.30 is allowed to write this register.",
 "attack_technique": "T0836",
 "evidence": ["zeek_modbus_log:1842", "zeek_modbus_log:1843"]
}
```


A.3.4 How we will measure success against B.2

Target	Metric	Method	Pass
Every device found	Devices in inventory ÷ devices in the Compose file; rogue device flagged	Compare inventory with the known list after the first hour; run S1	100%, rogue flagged
At least 95% of attacks detected	Detected runs ÷ total runs	Run each of the 6 required scenarios 5 times (30 runs); log each attack's start from the attack script	At least 29 of 30
Under 5% false alarms	False alerts ÷ all alerts, plus false alerts per 24 hours of normal traffic	Overnight normal run plus the held-out hour; every alert is checked against the attack log	Below 5%, and the per-day count is reported
Detection in under about 15 minutes	Alert time minus attack start	Timestamps from the attack scripts and the alert log	Every run under 15 minutes; rules should take seconds, ML a minute or two
No impact on control traffic	Poll success rate and 95th-percentile poll round-trip time, with and without the sensor	Run SCADA polling for the same period with capture off and on	No failed polls; no meaningful rise in latency

A.3.5 Known risks to the plan

- **IEC-104 parsing.** ICSNPP does not obviously include IEC-104. Fallback plan: the CERT.LV Zeek plugin, then Wireshark's `tshark` decoder on a rolling capture.
- **Mirroring in Docker.** Capturing on the bridge interface behaves like a mirror port but is not identical to a real switch SPAN. We will state this in the demo.
- **ML false alarms.** If the Isolation Forest is noisy, rules stay primary and ML alerts are limited to the scenarios where rules are weak (S5, S7, S8).

- **What may not work (planned for the video):** frozen-telemetry detection (S7) is the most likely to be only partly reliable, because a careful attacker can replay values with realistic noise.

Hurdles, open questions and references

Hurdles we expect, and how the design handles them

Hurdle	Why it matters	How the design handles it
No access to a real plant	We cannot know real traffic, register maps or maintenance habits	Build a lab from public tools (pymodbus, OpenPLC, lib60870); say plainly that results are from simulation; validate rules on third-party captures
Few labelled attack datasets	Most are small, simulated and narrow; none is a solar plant (A4)	Generate our own labelled attacks with known start times; use public sets only as checks
False alarms destroy trust	Operators stop reading a tool that cries wolf	Rules are primary and explicit; every alert says why in plain words; ML alerts are limited to cases where rules are weak; false alarms are measured and reported
Proprietary vendor protocols and encrypted channels	A passive sensor cannot decode what it cannot read (for example TLS vendor tunnels, cloud-only inverters)	Monitor metadata and endpoints; read firmware-version and identification registers; use the gateway log for vendor sessions; state the blind spots
Harsh field conditions	Heat, dust, power cuts and slow links in a desert park	Design considerations, not tested in the prototype: fanless industrial hardware rated for high temperature, DC supply with battery ride-through, write-safe storage that recovers from power loss, clock resync after an outage, store-and-forward alerts, local detection that works with the link down
Regulation is still settling	Six provisions of the 2026 Regulations are deferred to later orders (A5)	Keep the data model general; record requirements as a checklist that can change

Three open questions we could not answer

1. **Can one park-level security team satisfy each developer's own duties under the 2026 Regulations?** The rules call for a CISO and alternate and a round-the-clock security function per covered entity, and a 50 MW threshold for generators. It is unclear to us whether a park owner can run a shared team on behalf of many developers, and whether the threshold applies per plant or per company. The answer decides who the customer is.

2. **How much of the real inverter and logger traffic is readable?** We assume Modbus TCP with SunSpec-like registers. If a large share of devices in the park use proprietary protocols or cloud-only links, the sensor's coverage and the value of the product fall. Only a site survey can answer this.
3. **What does normal look like in a real plant, and how often does a legitimate change look like an attack?** Grid-operator curtailment orders, maintenance windows and firmware updates all change set-points and sessions. We cannot estimate the real false-alarm rate until we see months of real plant data.

References

Attacks and threat reports

- ESET, Industroyer2: Industroyer reloaded (April 2022)
- The Hacker News, Russian hackers tried attacking high-voltage electrical substations in Ukraine
- Netresec, Industroyer2 IEC-104 analysis and PCAP files
- CISA, IR-ALERT-H-16-056-01: Cyber-attack against Ukrainian critical infrastructure
- CISA, MAR-17-352-01 HatMan: safety system targeted malware
- FBI/CISA, TRITON malware remains threat to global critical infrastructure
- Wikipedia, Viasat hack; The Stack, Viasat KA-SAT outage; TechForge, Viasat satellites Europe offline
- Malwarebytes, China's RedEcho accused of targeting India's power grids; EastMojo, China attacked India's power sector (secondary reports of the Recorded Future study)
- CISA et al., AA24-038A: PRC state-sponsored actors compromise and maintain persistent access to US critical infrastructure
- MITRE, ATT&CK for ICS (technique IDs as given in the A3 tables; some were cross-checked against secondary mirrors of the matrix)

Packet captures and datasets

- Netresec, 4SICS ICS lab PCAP files; ICS-pcap collection
- Canadian Institute for Cybersecurity, CIC Modbus Dataset 2023
- Radoglou-Grammatikis et al., IEC 60870-5-104 Intrusion Detection Dataset and DNP3 Intrusion Detection Dataset
- Arifin et al., Dataset for NIDS on SCADA IEC 60870-5-104 (restricted access)
- IEEE DataPort, Cyber-security Modbus ICS dataset
- ETRI, HAI security dataset; Shin et al., HAI 1.0
- Morris et al., power system attack datasets, as described in CRUPL (arXiv 2503.00358)
- Systematic review of malicious industrial network traffic datasets; On the elements of datasets for CPS security; Survey on ICS testbeds and datasets

Regulation and standards

- Beacon Security, The CEA Cyber Security in Power Sector Regulations, 2026: what each chapter requires (links the Gazette notification)
- PwC India, CEA notifies India's first legally binding cyber security framework for the power sector
- Indian Infrastructure, CEA notifies Cyber Security in Power Sector Regulations, 2026

- Drishti IAS, Cybersecurity guidelines for power sector; Swarajya, Cybersecurity guidelines for power sector released (CEA 2021 Guidelines)
- Nishith Desai Associates, CERT-In directions of 28 April 2022; Khaitan & Co, Ergo note on the CERT-In direction
- IEC, IEC 62443 guidance; Cisco, ISA/IEC 62443-3-3 overview

Market and tools

- Microsoft, Defender for IoT pricing and on-premises management console retirement; O365HQ, OT site licence listing
- RFP.wiki, Nozomi Networks vs Dragos and Nozomi Networks vs Claroty; Decryption Digest, OT/ICS security 2026 comparison; Ciphers Security, Best OT security platforms 2026
- Idaho National Laboratory, Malcolm network traffic analysis tool suite; Malcolm release notes
- Apache Guacamole, TOTP authentication, 1.0.0 release notes

Further reading named in the exercise but not cited above: NIST SP 800-82 Rev. 3, CEA Cyber Security Guidelines for the Power Sector (2021 text), SANS ICS resources, Dragos Year in Review, CISA ICSNPP and Malcolm GitHub repositories, and the pymodbus, OpenPLC and lib60870 documentation.

SUPPLEMENTARY TECHNICAL VALIDATION ADDENDUM

Added material · original report retained without deletions

Purpose. This addendum strengthens the report's reproducibility and makes the boundary between researched facts, design assumptions, and prototype results explicit. It supplements the existing A1–A6 and Part B bridge; it does not replace or rewrite them.

B.1 Evidence status and claim discipline

The report describes a proposed prototype and a test plan. Unless a result is accompanied by a dated run log, packet capture, configuration snapshot and calculation, it must be presented as a target or hypothesis—not as a measured achievement. In particular, the 95% detection objective, false-positive target, alert latency and bandwidth estimates are acceptance criteria to be tested.

Statement type	How it should be presented	Minimum supporting evidence
Established external fact	State the fact and cite the primary or authoritative source.	Source URL, publication/update date, and the exact section supporting the claim.
Reference-plant assumption	Use "typical", "assumed" or "to confirm during site survey".	Assumption register; site network diagram or stakeholder confirmation when available.
Prototype design	Use "designed to", "planned" or "will test".	Architecture/configuration and reproducible steps.
Measured result	Give the value, denominator, test conditions and limitations.	Timestamped logs, PCAPs, run IDs, confusion matrix or calculation sheet.
Commercial estimate	Label as indicative and date it; avoid presenting secondary listings as vendor quotes.	Public listing or vendor quote, currency, licence scope and included services.

B.2 Reproducible validation plan

Use a fixed test protocol so another reviewer can reproduce the result. Keep normal traffic, attack traffic and evaluation labels separate. Run the detector in a clean environment with a versioned configuration, and save the raw PCAP and alert output for every run.

Step	Procedure	Record to retain
1. Freeze the build	Record Docker image tags, package versions, rule files, model seed and configuration hash.	build_manifest.txt; docker compose config output.
2. Capture baseline	Run normal polling and approved set-point changes for at least the duration stated in A.3. Keep a separate held-out period.	baseline.pcap; start/end timestamps; device inventory.
3. Inject one scenario at a time	Use the scenario script; write the attack start time to a machine-readable log. Never target real plant equipment.	scenario ID, run ID, start/end time, source host and expected behaviour.
4. Match alerts to events	Define a detection window before testing. Count a run as detected only	alerts.jsonl; event-to-alert matching table.

	when the expected scenario alert appears inside that window.	
5. Calculate metrics	Report detection rate, precision, recall, false alerts per hour and detection latency. Include missed events and duplicates.	Confusion matrix and per-scenario results.
6. Repeat and report	Repeat each required scenario, publish totals as well as percentages, and describe any exclusions.	Reproducibility notes and a short limitations statement.

B.3 Metrics and interpretation

Metric	Definition	Reporting caution
Detection rate / recall	True positive attack runs ÷ all attack runs.	State the number of runs. For example, 29/30 is 96.7%, but a small sample still has wide uncertainty.
Precision	True positive alerts ÷ all alerts classified as attack alerts.	A detector can have high recall and still generate too many false alarms.
False alerts per hour	False positive alerts during held-out normal traffic ÷ hours observed.	Report normal hours and whether approved maintenance changes were included.
Detection latency	Alert timestamp minus scripted attack-start timestamp.	Use synchronized clocks; report median and a high percentile, not only the best run.
Inventory coverage	Known devices discovered ÷ devices actually present in the test topology.	A device that is silent during the capture may not be discoverable from packets alone.
Data sent upstream	Bytes transmitted by the sensor for a defined observation period.	Measure with interface counters; the existing KB/hour figure is a design estimate until tested.

B.4 Evidence to capture for the final demonstration

The report already identifies four Wireshark figures in A2.4. Insert genuine screenshots from the actual tool run where possible; do not fabricate packet evidence or use a diagram as if it were a capture. Redact public IPs, credentials, customer identifiers and unrelated personal data.

Evidence item	What it should show	Suggested filename
Modbus read	Request and response expanded; function code, unit ID, register range and endpoints visible.	evidence_modbus_read.png
Modbus write	Write function, target register/value and source host visible; explain the register map is illustrative unless validated.	evidence_modbus_write.png
IEC-104 command	Decoded ASDU type/cause/object address and source/destination, if the selected capture actually contains a command.	evidence_iec104_command.png
Device inventory	Conversations/endpoints or the	evidence_device_inventory.png

	prototype inventory before and after the rogue-device scenario.	
Detection result	Scenario start time, alert timestamp, severity, reason and linked evidence identifier.	evidence_detection_timeline.png
Metrics summary	Per-scenario run counts, detections, false alerts and latency; include failed runs.	evidence_test_results.png

B.5 Protocol and visibility caveats

A passive sensor only sees traffic delivered to its monitoring interface. A switch mirror/SPAN session can omit packets if misconfigured or oversubscribed, and traffic on a different VLAN, serial segment, encrypted tunnel or vendor cloud path may be invisible. Coverage should therefore be stated as “observed at the configured tap point”, not “the entire plant is monitored”, until validated against the network topology.

Protocol security is implementation-dependent. Avoid the blanket claim that all industrial protocols have no authentication: base Modbus/TCP and IEC 60870-5-104 deployments commonly lack native message authentication, while extensions and secure configurations exist for several protocols. OPC UA, MQTT/TLS, IEC 62351, DNP3 Secure Authentication and Modbus/TCP Security must be assessed by actual version, mode and vendor configuration. A packet parser cannot decrypt traffic protected by TLS or a VPN; metadata and endpoint/gateway logs are the fallback.

A decoded write is not automatically malicious. It may be an approved curtailment order, commissioning operation, maintenance action or legitimate controller command. Detection should combine source identity, register/object address, maintenance window, expected sequence and operator/change records. The sensor should alert and preserve evidence; it should not automatically block or alter safety-critical control traffic in the initial prototype.

B.6 Primary-source reference links for final verification

These links are added as a convenient verification list. Before submission, confirm the page title, revision/date and the specific section used; legal and vendor documentation can change. The original reference list above is retained.

- **CISA — Cybersecurity Performance Goals / ICS guidance —** https://www.cisa.gov/topics/industrial-control-systems
- **CISA — Ukraine power grid incident alert IR-ALERT-H-16-056-01 —** https://www.cisa.gov/news-events/ics-alerts/ir-alert-h-16-056-01
- **CISA — TRITON / HatMan malware analysis MAR-17-352-01 —** https://www.cisa.gov/news-events/analysis-reports/ar17-352a
- **CISA et al. — PRC state-sponsored actors / Volt Typhoon, AA24-038A —** https://www.cisa.gov/news-events/cybersecurity-advisories/aa24-038a
- **MITRE ATT&CK for ICS — technique matrix —** https://attack.mitre.org/matrices/ics/

• **NIST SP 800-82 Rev. 3 — Guide to Operational Technology Security —** https://csrc.nist.gov/pubs/sp/800/82/r3/final
• **CERT-In — Directions under section 70B, 28 April 2022 —** https://www.cert-in.org.in/PDF/CERT-In_Directions_70B_28.04.2022.pdf
• **Central Electricity Authority — official cyber security regulations page —** https://cea.nic.in/
• **IEC — IEC 62443 series overview —** https://www.iec.ch/standards
• **Wireshark — display filter reference —** https://www.wireshark.org/docs/dfref/
• **Zeek — documentation —** https://docs.zeek.org/
• **Malcolm — network traffic analysis tool suite —** https://github.com/cisagov/Malcolm
• **Modbus Organization — Modbus specifications —** https://www.modbus.org/specs.php
• **OPC Foundation — OPC UA security overview —** https://opcfoundation.org/about/opc-technologies/opc-ua/

B.7 Final submission checklist

• Confirm the assignment brief's required sections, page range and naming convention.
• Check every URL and add inline citations near factual claims, not only a bibliography entry.
• Confirm the 2026 CEA regulation details directly against the official Gazette notification; label legal interpretation as non-legal advice.
• Insert real Wireshark and prototype screenshots only after running the commands; otherwise leave them clearly marked as planned evidence.
• Keep measured results separate from proposed targets; do not claim detection accuracy or false-positive performance before the tests run.
• Check that figures, tables, page numbers, headings and references render correctly in both Word and PDF.
• Remove or anonymize any API keys, IPs, credentials or identifying data from screenshots and logs.